40.11

Consulting Rotation

One on-duty tester at the front door; a whole practice behind the answer.

The desk has two connected jobs

PARTNER SUPPORT

Interpret a finding. Explain test evidence and general remediation direction. Clarify the retest question and route the next action.

TEAM SUPPORT

Peer-review technical evidence, scope and reports. Back up the on-duty tester on urgent or difficult work.

Not a new-test intake, a policy-approval desk, or a shortcut around the issue record.

Classify before you answer

1. **What is being asked?**
2. **Which finding / record?**
3. **What evidence exists?**
4. **Who owns the decision?**
5. **What happens next?**

If it is a new test or a broader scope, route it to engagement intake—not the consulting queue.

A useful reply has five parts

ACKNOWLEDGE	Show the question was received.
GROUND	Name the existing finding and exact evidence.
ANSWER	Give the technical explanation you can support.
LIMIT	Say what you cannot decide or what remains untested.
NEXT	Name the action, owner, and destination.

The on-duty tester should not stand alone

ANSWER

Known method, complete evidence, clear scope, no new decision authority.

PEER REVIEW

Ambiguous reproduction, report quality, unfamiliar technology, conflicting evidence.

ESCALATE

Sensitive release, urgent safety/incident concern, policy or risk approval, cross-team ownership.

Document the second opinion and the route used—not just the name of the person you asked.

Scenario 1 · “I think this is a false positive”

INBOUND

An owner disputes a reported access-control issue. The original screenshot is ambiguous; the repro step may use the wrong account.

BEST NEXT MOVE

Acknowledge. Re-open protected evidence. Ask a peer to review role and request context. State what is and is not confirmed. Correct the record if needed.

Scenario 2 · “Who fixes the shared component?”

INBOUND

A tested application and several other teams use the same component. The owner asks the desk to assign enterprise-wide remediation.

BEST NEXT MOVE

Explain the tested instance and evidence. Invite the relevant security and business partners to the owner discussion. Route broad-pattern ownership and scope through local governance.

Scenario 3 · “Send the report to this auditor”

INBOUND

A requester claims an urgent external audit need and asks for the full report and reproduction details by email.

BEST NEXT MOVE

Acknowledge without attaching. Verify requester, purpose, classification, and approval path. Route disclosure through the authorized owner; log exactly what is released.

Handoff is part of the answer

OPEN

What came in? Which record and owner? What is the response clock locally?

ACTIVE

What was checked? Who reviewed it? What is pending from whom?

CLOSED / ROUTED

What answer went out? What next action and destination were named?

A rotation is one staffed front door with team backup—not a string of private DMs.

Adapt the desk to the load

KEEP THE HUMAN BAR

Technical judgment, peer challenge, sensitive disclosure, high-consequence escalation, and the final answer remain accountable.

AUTOMATE WITH EVIDENCE

Intake classification, duplicate detection, record lookup, draft assembly, SLA visibility, and handoff can assist—but require source checks, redaction, and human disposition.

Measure whether questions are resolved well—not simply how many replies were sent.